

CSRF where Referer validation depends on header being present

Category: Cross-Site Request Forgery (CSRF)

Platform: PortSwigger Web Security Academy

Difficulty: Practitioner

Tool: Burp Suite

Objective

Exploit a CSRF vulnerability caused by improper validation of the HTTP **Referer** header.

Vulnerability

The application attempts to prevent CSRF attacks by validating the **Referer** header. However, the validation is only performed when the header is present. If the header is removed, the application fails open and processes the request without verifying its origin.

Methodology

1. Intercepted the sensitive request using Burp Suite.
2. Examined the server-side validation of the **Referer** header.
3. Tested the request with the **Referer** header removed.
4. Observed that the application accepted the request despite the missing header.
5. Used this behavior to construct a CSRF attack that omitted the **Referer** header.
6. Confirmed that the intended state-changing action was successfully performed.

Impact

An attacker can bypass the application's Referer-based CSRF protection and potentially perform unauthorized actions on behalf of an authenticated victim.

Remediation

The application should not treat a missing **Referer** header as trusted. Implement strong CSRF tokens and, where appropriate, validate the **Origin** and **Referer** headers using a fail-closed approach.

References

- PortSwigger Web Security Academy – CSRF
- OWASP – Cross-Site Request Forgery Prevention